



SSTI Note



Bối cảnh (Context)

Trang web tạo Landing Page cá nhân cho phép bạn nhập các đoạn văn bản có cấu trúc để hiển thị linh hoạt. Nhà phát triển sử dụng một Template Engine (như Jinja2 hoặc Twig) để tự động thay thế tên người dùng vào trang web, ví dụ: `Xin chào {{ user.name }}`.

Họ cho phép người dùng tự do nhập các biểu thức `{{ ... }}` vào giao diện mà không hề có lớp kiểm tra an toàn nào, với suy nghĩ rằng Template Engine chỉ sinh ra HTML.



Mục tiêu (Objective)

- **Nhiệm vụ:** Từ việc có thể in ra kết quả tính toán trên trang, hãy nâng cấp lên thành việc thực thi một lệnh hệ điều hành (RCE) trên máy chủ.
- **Vấn đề / Lỗ hổng: Server-Side Template Injection (SSTI).** Khi nhận dữ liệu người dùng chứa các cú pháp của Template Engine mà không được sanitize, Engine sẽ biên dịch và thực thi cú pháp đó. Hacker có thể lợi dụng các class/object có sẵn trong môi trường (như ở Python/Jinja2 là `__class__`, `__mro__`, `__subclasses__`) để tìm đường đến thư viện hệ thống (os) và chạy lệnh.
- **Flag:** Chạy lệnh `cat /flag.txt` trên máy chủ và hiển thị kết quả.



Gợi ý (Hints)

- Thử nhập `{{ 7 * 7 }}` xem nó có in ra 49 không. Nếu có, nó dính SSTI.
- Tra cứu tài liệu về "SSTI Payload" cho ngôn ngữ/engine tương ứng (Python/Jinja2, Node/Pug, Java/Thymeleaf...). MRO (Method Resolution Order) là chìa khóa trong Python.